COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.4 · On-path Attacks

Mestre CyberSec · **Lesson 2.4 — On-path Attacks** (5:30) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: On-path (antigo man-in-the-middle): atacante fica no MEIO da comunicação e INTERCEPTA ou ALTERA o tráfego. ARP spoofing (mentira no MAC table local — o tráfego passa pelo atacante); evil twin AP; DNS poisoning. Defesa: TLS em tudo (o S importa), VPN em rede pública, ARP inspectio

💡 Key Exam Highlights & Critical Concepts

- On-path (antes MITM): intercepta e/ou altera comunicação
- ARP spoofing: mentira o MAC — redireciona tráfego ao atacante
- Defesa nº1: HTTPS em tudo (o TLS autêntica o endpoint)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'traffic intercepted between two parties' = on-path/MITM

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — On-path Attacks)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• On-Path Attack (MITM)

An attack where the adversary positions themselves between two communicating parties to intercept, read, or alter traffic without either side knowing. Formerly called Man-in-the-Middle (MITM).

⚠️ ***Exam Trap:*** *Qualquer questão dizendo 'traffic intercepted between two parties' ou 'attacker sits in the middle of communication' = on-path. CompTIA atualizou o nome: MITM e on-path são o mesmo ataque.*

• ARP Spoofing

Sending forged ARP replies on a local network to associate the attacker's MAC address with a legitimate IP (like the default gateway), redirecting traffic through the attacker's machine. Works because ARP has no authentication.

⚠️ ***Exam Trap:*** *ARP spoofing é o MECANISMO técnico mais cobrado para viabilizar um ataque on-path na LAN. Gatilho: 'MAC table', 'gateway traffic redirected', 'local network interception'. Lembre: ARP não autentica nada — qualquer um pode responder.*

• Evil Twin (AP)

A rogue wireless access point configured to mimic a legitimate one (same/similar SSID), tricking users into connecting so the attacker can intercept all their traffic — a wireless form of on-path attack.

⚠️ ***Exam Trap:*** *Não confunda: Evil Twin = AP falso com SSID legítimo (interceptação); Rogue AP = AP não autorizado plugado na rede corporativa. Gatilho: 'fake Wi-Fi hotspot', 'users connected to malicious access point'.*

• DNS Poisoning

Injecting false DNS records into a resolver's cache so that legitimate domain names resolve to attacker-controlled IP addresses, silently redirecting users to malicious sites.

⚠️ ***Exam Trap:*** *Se a questão fala em 'users redirected to fake site despite typing correct URL', pense em DNS poisoning/spoofing. Defesas cobradas: DNSSEC (autentica as respostas) e validação de respostas DNS.*

• Transport Layer Security (TLS)

Cryptographic protocol that encrypts traffic and authenticates the server endpoint via digital certificates, defeating on-path attackers even when they can see the traffic. The 'S' in HTTPS.

⚠️ ***Exam Trap:*** *Defesa nº1 contra on-path segundo Messer: 'TLS em tudo — o S importa'. A questão-chave: interceptar não basta, pois com TLS o atacante vê só dados cifrados. Um alerta de certificado inválido no navegador pode indicar um ataque on-path em andamento!*

• Virtual Private Network (VPN)

Creates an encrypted tunnel between the client and a trusted endpoint, protecting all traffic from interception on untrusted networks like public Wi-Fi — a primary defense against on-path attacks.

⚠️ ***Exam Trap:*** *Gatilho clássico: 'user on public Wi-Fi / coffee shop / hotel network, how to protect traffic?' = VPN (túnel criptografado). A VPN protege mesmo se o usuário cair num Evil Twin.*

• Dynamic ARP Inspection (DAI)

A switch security feature that validates ARP packets against a trusted binding table (typically built by DHCP snooping) and drops forged ARP replies, directly blocking ARP spoofing on the LAN.

⚠️ ***Exam Trap:*** *Se a pergunta pedir como PREVENIR ARP spoofing/poisoning em switches = DAI. Memorize a dupla: DHCP snooping constrói a tabela → DAI a usa para validar o ARP. Costuma cair junto.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Birthday Attack & Hash Collisions

🏠 **Real-World Analogy:** In a room of just 23 people, there is a greater than 50% statistical probability that two people share the exact same birthday. The reason is that you are not searching for someone matching YOUR specific birthday; you are searching for ANY matching pair. In a Birthday Attack, an attacker creates two radically different files (a legitimate lease and a fraudulent property transfer) and makes invisible formatting tweaks until both generate the identical cryptographic hash output. The attacker gets the victim to digitally sign the benign file, but applies that valid digital signature to the fraudulent document.

🔍 **Root Cause & Background:** The birthday paradox drastically diminishes the mathematical trials needed to find two distinct inputs yielding identical hash outputs (reducing complexity from 2^n to 2^(n/2)). Weak hash algorithms with short digest lengths (MD5 128-bit, SHA-1 160-bit) make computational collisions achievable.

🛡️ **GRC Auditor Perspective:** Strictly deprecate vulnerable hashing algorithms (MD5 and SHA-1) across enterprise standards to meet PCI-DSS and FIPS 140-3 mandates; standardize exclusively on SHA-256/SHA-512 (SHA-2) or SHA-3.

⚠️ **How CompTIA Tests This:** Trigger: 'attacker finds two distinct inputs resulting in the exact same cryptographic hash value' -> Birthday Attack / Hash Collision. Classic exam examples: MD5 and SHA-1.

📌 Downgrade Attack & SSL Stripping

🏠 **Real-World Analogy:** A Downgrade Attack is like arriving at a consulate prepared to speak in modern encrypted code, but a dishonest guard at the gate insists: 'Our modern cipher is offline; you must converse in an obsolete 16th-century dialect', allowing eavesdroppers to easily decipher your conversation. SSL Stripping is an on-path attacker intercepting an encrypted padlock envelope (HTTPS), discarding the lock, and substituting a transparent clear plastic sleeve (HTTP) before forwarding it to the user, who mistakenly browses without encryption.

🔍 **Root Cause & Background:** Backward compatibility leads web servers to permit legacy, broken protocol handshakes (SSLv3, TLS 1.0). In SSL Stripping, an on-path adversary intercepts unencrypted initial HTTP GET requests and withholds the 301/302 HTTPS redirect, keeping the client communicating over unencrypted plaintext.

🛡️ **GRC Auditor Perspective:** Disable obsolete cipher suites and protocols on all load balancers (purging SSLv3, TLS 1.0, TLS 1.1); mandate HTTP Strict Transport Security (HSTS) with the `preload` directive to instruct client browsers never to issue cleartext HTTP requests.

⚠️ **How CompTIA Tests This:** Trigger: 'attacker forces connection to negotiate a weaker, outdated protocol version' -> Downgrade Attack. Trigger: 'transparent conversion of HTTPS requests into unencrypted HTTP' -> SSL Stripping. Definite defense: HSTS.

📌 Replay Attacks & Nonce/Timestamp Defenses

🏠 **Real-World Analogy:** A Replay Attack is like an intruder tape-recording an executive unlocking a voice-activated vault door. Later that night, the burglar plays back the exact audio recording. The lock opens because it only evaluates the raw audio signal. A Nonce (number used once) stops this by requiring a unique challenge: the vault displays 'Combine your passphrase with one-time code 7392'. Because code 7392 is only valid for 3 seconds and never repeated, the recorded audio playback is promptly rejected as stale.

🔍 **Root Cause & Background:** Authentication exchanges lacking time-bound ephemeral entropy transmit reusable tokens or hashes. Threat actors capture the network transmission and retransmit the exact payload to impersonate the client without needing to crack the secret.

🛡️ **GRC Auditor Perspective:** Deprecate legacy authentication protocols vulnerable to replay (NTLM) in favor of Kerberos with strict Kerberos timestamp skew tolerances (NTP synchronization); enforce session nonces and ephemeral challenges in API protocols.

⚠️ **How CompTIA Tests This:** Trigger: 'attacker sniffs valid session authentication data and resends the packets to authenticate' -> Replay Attack. Primary defenses: Cryptographic Nonces and Timestamps.

📌 Known Plaintext vs. Ciphertext-Only Attacks

🏠 **Real-World Analogy:** Ciphertext-Only is a cryptanalyst finding a locked diary written in an unrecognizable alien code with zero clues regarding its content or language. Known Plaintext is when the analyst intercepts the encrypted file but already knows with absolute certainty that the first 50 characters represent a standard formal header (such as 'CONFIDENTIAL - EXECUTIVE MEMO:'). By matching the known plaintext header against the corresponding encrypted ciphertext block, the adversary mathematically deduces the encryption key.

🔍 **Root Cause & Background:** Improper encryption modes (such as AES in Electronic Codebook / ECB mode) encrypt identical plaintext blocks into identical ciphertext blocks. When an attacker possesses predictable structural headers (file headers, standard salutations), they reverse-engineer key parameters.

🛡️ **GRC Auditor Perspective:** Ban deterministic cipher modes (such as ECB) across secure coding standards; mandate authenticated modes (AES-GCM) utilizing cryptographically random, non-repeating Initialization Vectors (IV).

⚠️ **How CompTIA Tests This:** Trigger: 'attacker possesses both encrypted ciphertext and the corresponding original plaintext for known message fragments' -> Known Plaintext Attack. If possessing solely raw encrypted ciphertext: Ciphertext-Only Attack.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Attacker produces two completely distinct plaintexts that resolve to the exact same cryptographic hash digest	**Hash Collision / Birthday Attack**
Attacker forces client and server to discard modern secure algorithms and fall back to a vulnerable legacy protocol	**Downgrade Attack**
Security response header directing browsers to communicate exclusively over encrypted HTTPS connections	**HSTS (HTTP Strict Transport Security)**
Attacker intercepts valid authentication packets and replays them to impersonate a legitimate user without cracking credentials	**Replay Attack**
One-time random numeric value incorporated into cryptographic handshakes to guarantee freshness and prevent replay	**Nonce (Number Used Once)**
Cryptanalyst utilizes known snippets of unencrypted plaintext alongside matching encrypted ciphertext to discover keys	**Known Plaintext Attack**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A security analyst at a hospital reviews switch logs and sees numerous ARP replies where the same MAC address claims to be the default gateway and several medical-device servers. Traffic between the servers and clinical workstations is being silently redirected. Which switch feature should the analyst enable to prevent this specific attack?

A) Dynamic ARP Inspection

B) DNSSEC

C) 802.1X port-based authentication

D) IPsec tunnel mode

QUESTION 2 · EXAM SCENARIO

A traveling salesperson connects to a wireless network named Airport_Free_WiFi at an airport. Shortly afterward, the browser displays a certificate warning for the company webmail site, and login credentials are suspected stolen. Investigators find a rogue access point broadcasting the same SSID with a stronger signal. Which attack best matches this scenario?

A) DNS cache poisoning

B) VLAN hopping

C) Evil twin

D) ARP spoofing

QUESTION 3 · EXAM SCENARIO

Employees at a branch office report that typing the internal payroll portal name resolves to an external IP address hosting a fake login page. The internal DNS resolver cache contains an entry that was not created by the authoritative server. Which security control directly validates DNS responses to prevent this type of record forgery?

A) Dynamic ARP Inspection

B) DNSSEC

C) WPA3-Enterprise

D) Port security

QUESTION 4 · EXAM SCENARIO

A remote employee must access corporate file shares from a coffee shop's open Wi-Fi. The company wants to protect all traffic from on-path interception, including protocols that do not natively use encryption. Which solution should the security team require?

A) Hiding the SSID on the employee laptop

B) Configuring static ARP entries for the corporate server

C) Using DNS over HTTPS only

D) A full-tunnel VPN with certificate-based authentication

QUESTION 5 · EXAM SCENARIO

A web application is configured to use HTTPS, but users on an untrusted network are sometimes redirected from the initial HTTP request to an attacker-controlled HTTP page before reaching the login page. Which control best prevents this SSL-stripping on-path attack for future visits?

A) HTTP Strict Transport Security

B) Dynamic ARP Inspection

C) DNSSEC

D) Network access control

QUESTION 6 · EXAM SCENARIO

In a campus LAN, several users suddenly receive IP configuration with a default gateway address that belongs to an unauthorized laptop. Their traffic is then routed through that laptop. Which switch feature most directly prevents rogue DHCP servers from assigning malicious gateway settings?

A) Dynamic ARP Inspection

B) DHCP snooping

C) Private VLANs

D) Spanning Tree Protocol

QUESTION 7 · EXAM SCENARIO

An administrator plans to enable Dynamic ARP Inspection on access switches to stop ARP spoofing. The switches currently have no Layer 2 security features configured. Which configuration is normally required for DAI to validate ARP packets against trusted bindings?

A) BGP route filtering

B) TLS inspection

C) DHCP snooping

D) RADIUS authentication for all users

QUESTION 8 · EXAM SCENARIO

A penetration tester on the same VLAN as a target uses forged ARP replies to make the target believe the tester's MAC address is the gateway. The tester then forwards packets to the real gateway while capturing them. Which term best describes this attack?

A) Denial-of-service attack

B) SQL injection

C) Cross-site scripting

D) On-path attack

QUESTION 9 · EXAM SCENARIO

Corporate laptops are configured to automatically join any wireless network named CompanyGuest. An attacker sets up a rogue AP with that name near a hotel lobby. Which configuration change most directly reduces the risk of laptops connecting to the rogue AP?

A) Disable automatic connection to open or untrusted SSIDs and require managed profiles

B) Enable port security on all access switches

C) Replace DNSSEC with DNS over HTTP

D) Turn on Spanning Tree Protocol on wireless controllers

QUESTION 10 · EXAM SCENARIO

An employee ignores a browser warning about an untrusted certificate while using public Wi-Fi. A security analyst later finds that the session was decrypted by an attacker presenting a self-signed certificate. Which user action would have most directly prevented the interception?

A) Enabling MAC address filtering

B) Stopping and not proceeding when the certificate warning appeared

C) Hiding the wireless SSID

D) Disabling the local firewall

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Dynamic ARP Inspection

Dynamic ARP Inspection validates ARP packets on untrusted switch ports against a trusted DHCP snooping binding table or static ARP ACL. It drops forged ARP replies that map the gateway IP to an attacker MAC, preventing the local on-path redirection. DNSSEC protects DNS records, 802.1X controls network access, and IPsec does not stop LAN ARP cache poisoning.

Question 2: Option C — Evil twin

An evil twin is a rogue access point that impersonates a legitimate SSID to lure clients. The stronger signal and certificate warning on the corporate site are consistent with the client connecting to the attacker AP and being intercepted. DNS cache poisoning affects name resolution, ARP spoofing is layer 2 on a LAN, and VLAN hopping is a switching attack, not a fake wireless AP.

Question 3: Option B — DNSSEC

DNSSEC provides cryptographic signatures for DNS records so validating resolvers can detect forged or altered responses. DAI protects ARP, WPA3-Enterprise protects wireless links, and port security limits MAC addresses on switch ports; none validates DNS record authenticity.

Question 4: Option D — A full-tunnel VPN with certificate-based authentication

A full-tunnel VPN encrypts all traffic from the endpoint to the corporate gateway, protecting even unencrypted protocols from on-path interception on public Wi-Fi. Hiding SSIDs, static ARP entries, and DoH alone do not protect general traffic. DoH only protects DNS queries.

Question 5: Option A — HTTP Strict Transport Security

HSTS instructs browsers to use HTTPS only for a domain and prevents protocol downgrade attacks such as SSL stripping after the first trusted visit. DAI, DNSSEC, and NAC address different layers and do not stop an HTTP-to-HTTPS downgrade at the application layer.

Question 6: Option B — DHCP snooping

DHCP snooping designates trusted switch ports for DHCP servers and blocks DHCP offers from untrusted ports, preventing rogue DHCP servers from assigning malicious gateway or DNS settings. DAI protects ARP, private VLANs restrict layer 2 isolation, and STP prevents loops.

Question 7: Option C — DHCP snooping

DAI normally relies on the DHCP snooping binding database to know which IP-to-MAC mappings are valid on each port. Static ARP ACLs can be used in some designs, but DHCP snooping is the standard prerequisite. BGP filtering, TLS inspection, and RADIUS authentication do not provide DAI bindings.

Question 8: Option D — On-path attack

Forging ARP replies to insert the attacker between the victim and gateway, then forwarding traffic while capturing it, is an on-path attack, often called man-in-the-middle. It is not primarily a DoS, SQL injection, or XSS.

Question 9: Option A — Disable automatic connection to open or untrusted SSIDs and require managed profiles

Disabling automatic connections to open or untrusted SSIDs and requiring managed wireless profiles prevents clients from silently joining an evil twin. Port security, DNS over HTTP, and STP do not prevent wireless client association to a rogue AP.

Question 10: Option B — Stopping and not proceeding when the certificate warning appeared

TLS protects against on-path interception only when the client validates the server certificate. Proceeding past an untrusted certificate warning allows an attacker with a self-signed certificate to terminate and read the TLS session. MAC filtering, SSID hiding, and disabling the firewall do not fix certificate validation.